

כתיבת דוח ותיעוד (Reporting)

מודול 16 — האקינג אתי מהיסוד

◀ הדוח = המוצר של הבדיקה

◀ מבנה דוח ו-Executive Summary

◀ כתיבת ממצא, CVSS, המלצות

◀ תיעוד תוך-כדי וכלים

למה הדוח הוא המוצר?

- ◀ הלקוח לא רואה אותך פורץ — רק את הדוח
- ◀ בדיקה מבריקה + דוח גרוע = כישלון
- ◀ ~30% מהזמן → תיעוד ודוח
- ◀ **חלק מהציון ב-PNPT/OSCP**

שלבי הבדיקה סביב הדוח

◀ Pre-Engagement — Scope, RoE, הרשאה

◀ תיעוד תוך-כדי — בזמן אמת!

◀ Reporting — ארגון וכתיבה

◀ Debrief + Retest

מבנה הדוח

◀ שער ופרטים + סיווג

◀ **Executive Summary**

◀ היקף ומתודולוגיה

◀ סיכום ממצאים → ממצאים מפורטים → נספחים

שני קהלים, שתי שפות

◀ הנהלה → Executive Summary (עסקי)

◀ צוות ID → ממצאים מפורטים (טכני)

◀ הדוח משרת את שניהם

◀ אותו סיפור, שתי שפות

Executive Summary

- ◀ הדף החשוב ביותר — למקבל ההחלטות
- ◀ מה נבדק + תמונת מצב + סיכון עסקי
- ◀ 3-5 המלצות מפתח
- ◀ **שפה עסקית, לא ז'רגון!**

כתיבת ממצא מקצועי

- ◀ **תיאור** — מה ואיפה
- ◀ **השפעה** — מה תוקף יכול
- ◀ **PoC** — צעדים + צילומים
- ◀ **תיקון + הפניות** (CVE/OWASP)

דירוג חומרה — CVSS

- ◀ ציון 0-10 לכל חולשה
- ◀ **Critical** 9-10 · **High** 7-8.9
- ◀ **Medium** 4-6.9 · **Low** 0.1-3.9
- ◀ דרג לפי **סיכון עסקי**, לא רק ציון

המלצות תיקון

- ◀ **ספציפי וישים** — לא "שפר אבטחה"
- ◀ מדורג לפי עדיפות (Critical קודם)
- ◀ קצר טווח (patch) + ארוך (מבני)
- ◀ מקושר לכל ממצא

תיעוד תוך-כדי

- ◀ צילומי מסך (Flameshot)
- ◀ לוג פקודות (script/tmux)
- ◀ CherryTree / Obsidian / Sysreptor
- ◀ כתוב מיד — לא מהזיכרון בסוף

סיכום מודול 16

- ◀ הדוח הוא המוצר — השקע בו
- ◀ Executive (עסקי) + ממצאים (טכני)
- ◀ ממצא: תיאור → השפעה → PoC → תיקון; CVSS
- ◀ תעד בזמן אמת
- ◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`

מזל טוב — סיימת את הקורס! 🎓

- ◀ עברת את כל שרשרת התקיפה
- ◀ ממבוא ומעבדה עד הדוח המקצועי
- ◀ הבא: **מבחן מעשי מסכם**
- ◀ מסלול המשך: **OSCP → PNPT → eJPT** 🚀